

Política de Segurança da Informação

Repositório de Arquivos BIM

Confidencialidade · Integridade · Disponibilidade · Conformidade LGPD

1 · Classificação da Informação

- Arquivos BIM (Building Information Modeling) são classificados como dados sensíveis de propriedade intelectual
- Formatos aceitos: .rvt, .ifc, .nwd, .nwc, .pln, .dwg, .dxf, .pdf — lista branca (allowlist), tudo mais é rejeitado
- Tamanho máximo por arquivo: 200 MB — delimita o escopo e reduz superfície de ataque
- Projetos de arquitetura contêm plantas, especificações e dados proprietários confidenciais

2 · Tríade CIA Aplicada ao Repositório BIM

Princípio	Implementação no Repositório BIM
Confidencialidade	Acesso restrito ao proprietário + compartilhamento explícito com consentimento LGPD
Integridade	Hash Argon2id, JWT assinado, arquivos imutáveis após upload
Disponibilidade	Soft delete — arquivo desativado, nunca destruído; dados recuperáveis

3 · Política de Autenticação e Identidade (IAM)

- Autenticação multifator obrigatória (MFA): senha + TOTP de 6 dígitos (RFC 6238)
- Hash de senha: Argon2id com salt único de 32 bytes por usuário — resistente a ataques de GPU e rainbow tables
- Token temporário pré-2FA: JWT com TTL de 5 minutos e claim stage: pre_2fa
- Token de acesso final: JWT com TTL de 60 minutos — stateless, expiração automática
- Proteção contra enumeração de usuários: respostas e tempo de resposta idênticos para e-mails válidos e inválidos

4 · Controle de Acesso e Princípio do Menor Privilégio

- Cada arquivo possui um único proprietário — acesso cruzado implícito não existe
- Compartilhamento granular: permissão restrita a download, controlada exclusivamente pelo dono
- Revogação de acesso imediata — proprietário pode encerrar qualquer compartilhamento a qualquer momento
- Identificação por matrícula: destinatário do compartilhamento deve ser usuário cadastrado no sistema
- Sem acesso administrativo global a arquivos de outros usuários

5 · Conformidade com a LGPD — Lei 13.709/2018

- Compartilhamento requer consentimento explícito do proprietário (campo lgpd_consent obrigatório)
- Data e hora do consentimento são registradas no banco de dados (lgpd_consent_at)
- Revogação de compartilhamento a qualquer momento — direito ao esquecimento parcial garantido
- Dados de identificação (e-mail, matrícula, nome) usados apenas para finalidade declarada

6 · Rastreabilidade e Auditoria

- Log de acesso registrado para cada operação: upload, download, compartilhamento, revogação e exclusão
- Cada entrada contém: identificador do arquivo, identificador do usuário, ação e timestamp UTC
- Não repúdio: toda ação é atribuída a um usuário autenticado e registrada de forma imutável
- Base para investigação de incidentes de segurança e auditorias de conformidade

7 · Ciclo de Vida dos Arquivos BIM

1. Upload	Envio do arquivo BIM pelo proprietário (formatos permitidos, ≤ 200 MB)
2. Armazenamento	Isolado por UUID do usuário no servidor; nome real substituído por UUID
3. Compartilhamento	Proprietário indica matrícula do destinatário + consentimento LGPD
4. Revogação	Proprietário remove acesso a qualquer momento; log registrado
5. Soft Delete	Arquivo marcado como excluído — dados preservados para auditoria

8 · Normas e Referências Aplicáveis

ISO/IEC 27001	Gestão de segurança da informação — base para controles de acesso e auditoria
LGPD — Lei 13.709/2018	Proteção de dados pessoais — consentimento obrigatório no compartilhamento
OWASP Top 10	Prevenção de injeção, auth quebrada, exposição de dados — guia de implementação
RFC 6238 (TOTP)	Padrão aberto para autenticação de dois fatores baseada em tempo
PHC — Argon2id	Algoritmo vencedor do Password Hashing Competition para hash de credenciais